LABORATORIO N.º 11

OWASP ZAP

Zed Attack Proxy

Análisis de seguridad web en entorno controlado · Kali Linux + DVWA

Módulos: History · Search · Alerts · Output · Spider · Active Scan · HTTP Sessions · AJAX Spider · WebSockets

1. Objetivo del laboratorio

Instalar y configurar **OWASP ZAP (Zed Attack Proxy)** en Kali Linux, encadenarlo como **proxy de interceptación** con el navegador Firefox, y realizar un análisis de seguridad completo sobre un entorno **controlado y autorizado** (DVWA en Docker). Finalmente, se documenta cada módulo de ZAP con su captura correspondiente y se genera el reporte.

Alcance ético: todas las pruebas de ataque se ejecutan sobre aplicaciones propias o diseñadas para ser atacadas (DVWA). El escaneo activo solo debe lanzarse contra sistemas sobre los que se tiene permiso explícito.

Herramientas y versiones

Componente	Detalle
Sistema operativo	Kali Linux 2025.4 (VirtualBox)
Herramienta principal	OWASP ZAP 2.17.0 (by Checkmarx)
Aplicación objetivo	DVWA (Damn Vulnerable Web Application) en Docker
Navegador	Firefox (configurado con proxy manual)
Puerto del proxy ZAP	8090

2. Instalación de OWASP ZAP en Kali Linux

Paso 1 y 2. Validar e instalar ZAP

Primero validamos si ZAP ya está instalado escribiendo el comando en la terminal. Si no existe, Kali sugiere el paquete y lo instalamos manualmente:

```
zaproxy
```

```
sudo apt update
sudo apt install zaproxy -y
```

En la terminal verás el proceso de descarga e instalación del paquete `zaproxy` (aprox. 222 MB):



Figura 1. Instalación de zaproxy desde la terminal de Kali Linux.

Paso 3. Verificar la instalación

Confirmamos la versión instalada y el entorno Java:

```
zaproxy --version
```

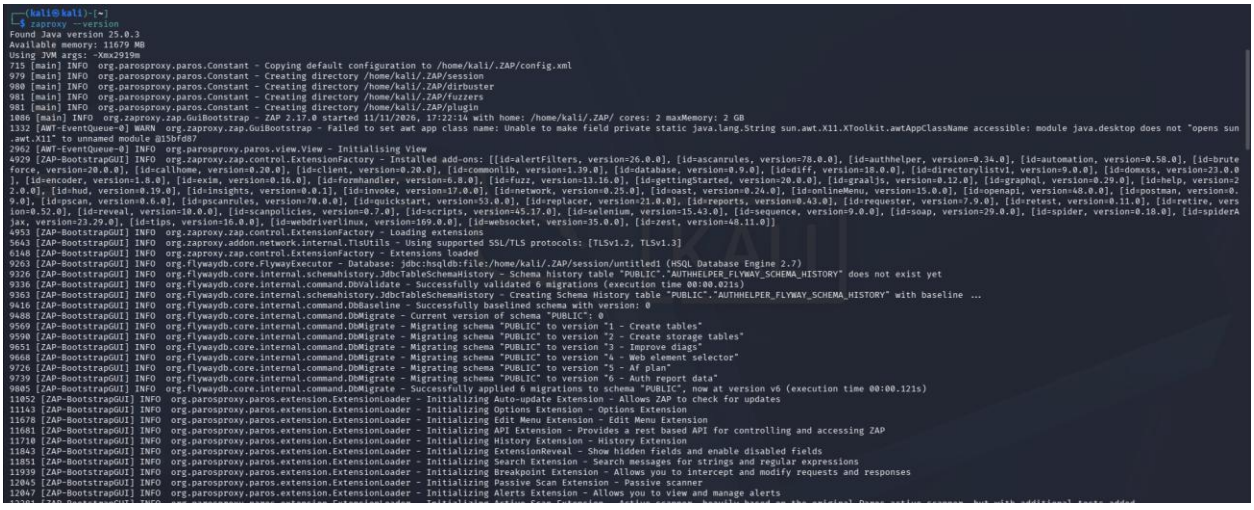


Figura 2. Verificación: Java 21.0.9 y ZAP 2.17.0 listo para ejecutarse.

Paso 4. Abrir OWASP ZAP

Puedes abrir ZAP de dos formas. **Desde la terminal**:

```
zaproxy
```

Desde el menú gráfico: Applications ▸ Web Application Analysis ▸ OWASP ZAP, o busca "zap" en el lanzador de aplicaciones.

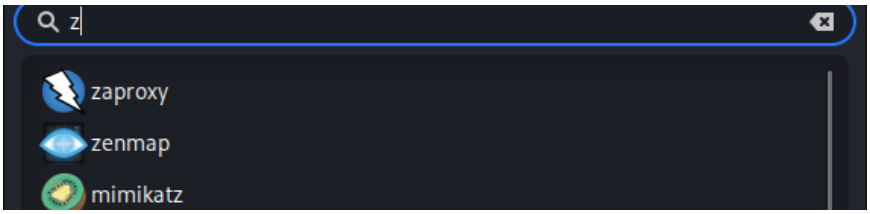


Figura 3. Búsqueda de ZAP en el menú de aplicaciones de Kali.

3. Preparación del entorno controlado (DVWA)

Paso 5. Levantar DVWA en Docker

DVWA es una aplicación web deliberadamente vulnerable, pensada para practicar. La levantamos en un contenedor Docker:

```
sudo docker run --rm -it -p 8080:80 vulnerables/web-dvwa
```

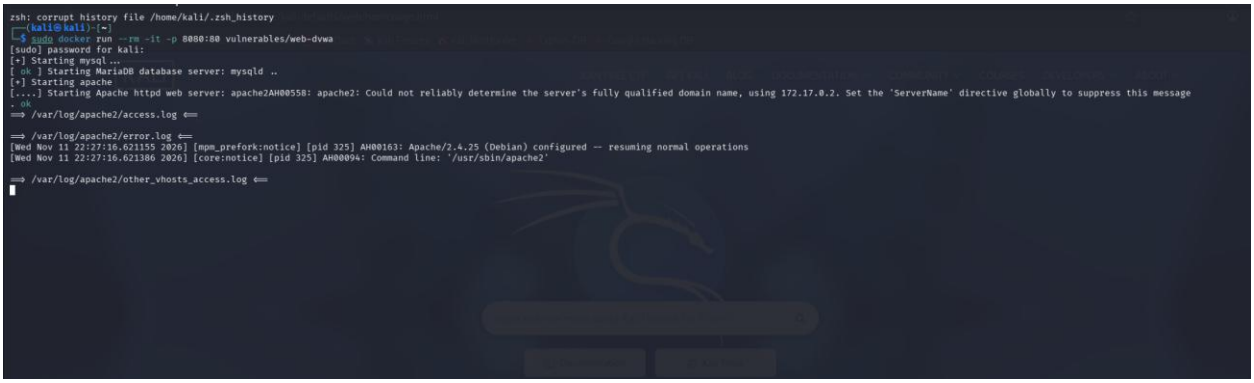


Figura 4. Contenedor Docker de DVWA en ejecución.

Abrimos Firefox y accedemos a la aplicación en `http://127.0.0.1:8080`:

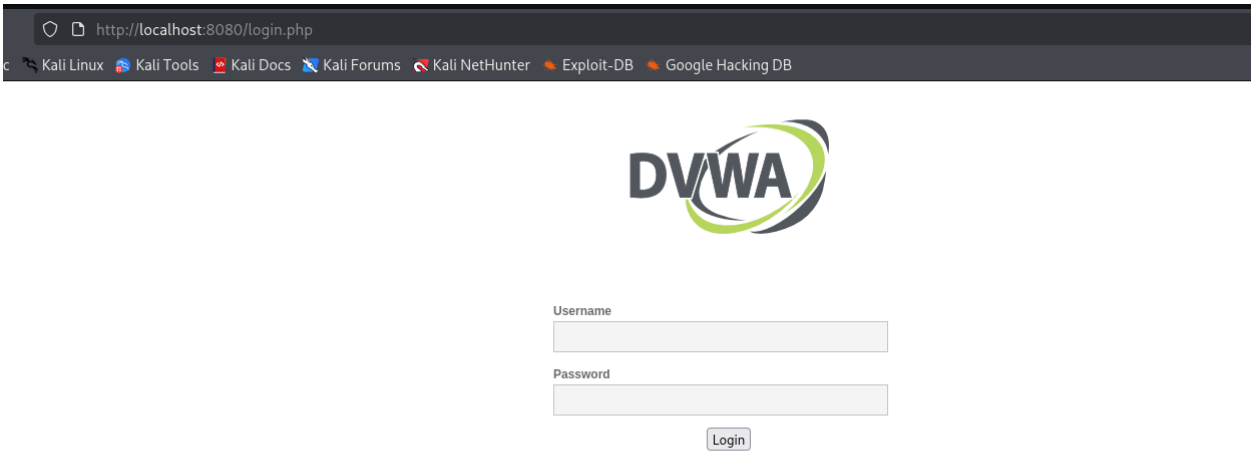


Figura 5. Pantalla de login de DVWA en el navegador — el entorno está activo.

4. Configurar el proxy en Firefox

Paso 6. Enrutar el tráfico de Firefox a través de ZAP

Para que ZAP pueda interceptar el tráfico, Firefox debe enviar sus peticiones al proxy de ZAP. En Firefox entra a Ajustes y busca "proxy":

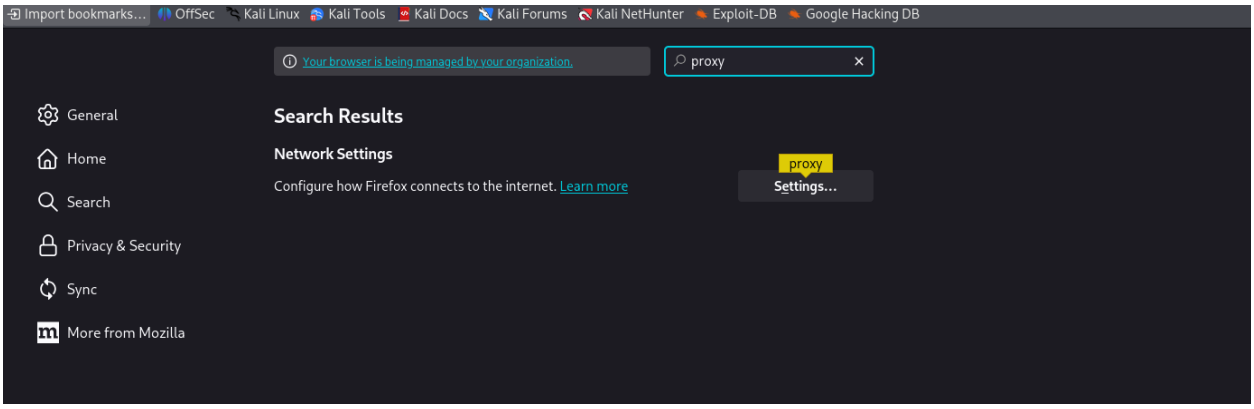


Figura 6. Búsqueda de la configuración de red (proxy) en los ajustes de Firefox.

Pulsa "Settings..." en Network Settings y configura un proxy manual:

Campo	Valor
Configuración	Manual proxy configuration
HTTP Proxy	127.0.0.1
Port	8090
Also use this proxy for HTTPS	✓ (activado)

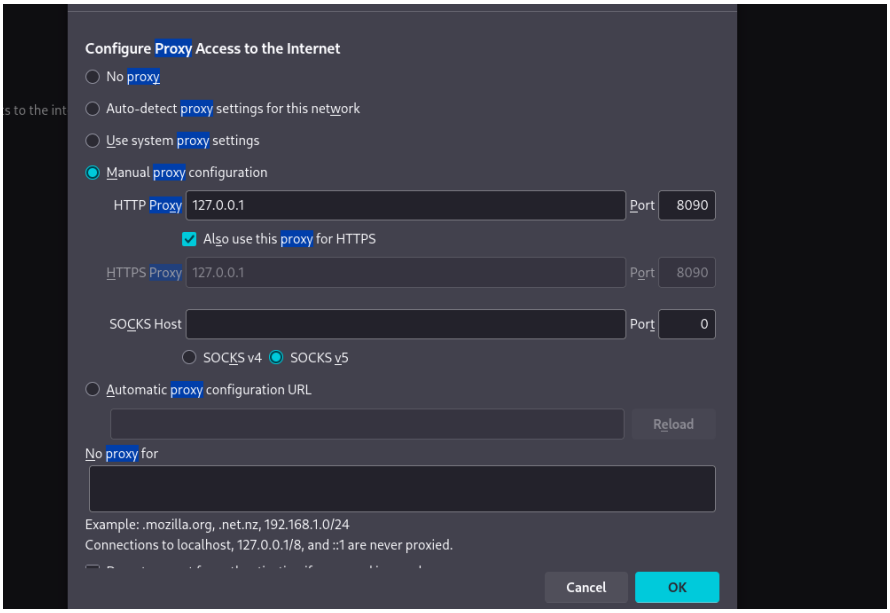


Figura 7. Configuración manual del proxy: 127.0.0.1 : 8090 para HTTP y HTTPS.

5. Primera ejecución de ZAP

Paso 7. Persistencia de la sesión

Al abrir ZAP por primera vez pregunta si deseas persistir la sesión. Para una prueba de laboratorio puede seleccionarse "No, I do not want to persist this session at this moment in time" y pulsar Start:

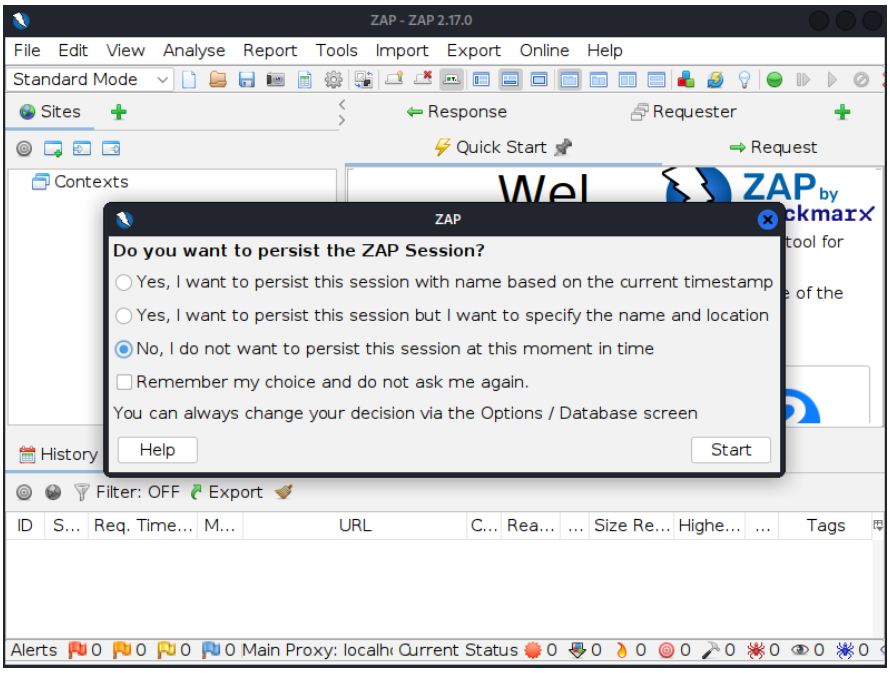


Figura 8. Diálogo de inicio de ZAP: decisión sobre persistir la sesión.

Paso 8. Cambiar el puerto del proxy en ZAP

ZAP debe escuchar en el mismo puerto que configuramos en Firefox (8090). En ZAP ve a **Tools ▸ Options**:

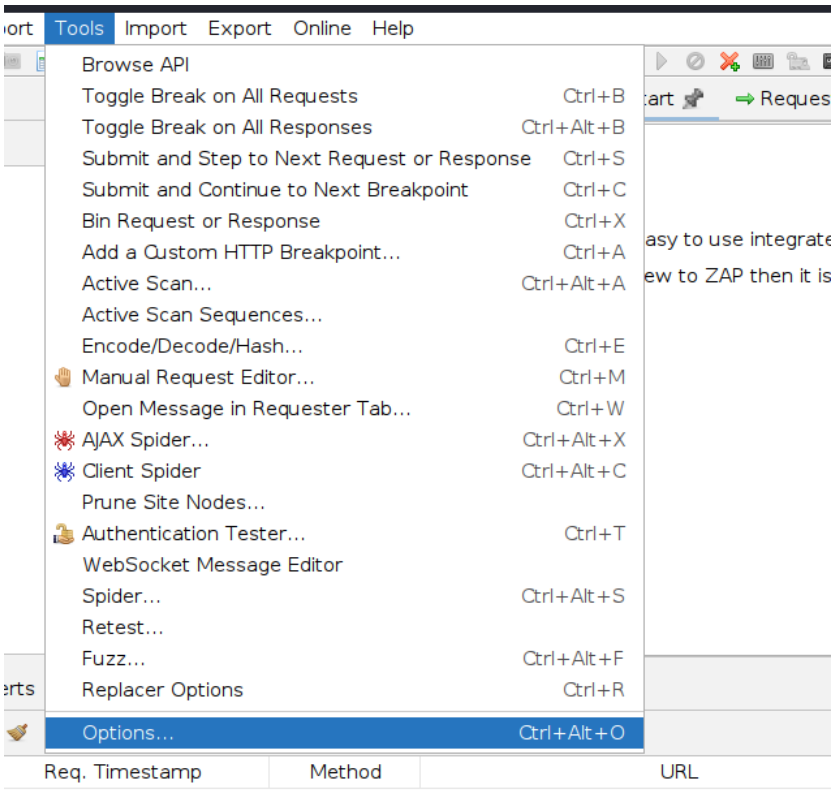


Figura 9. Menú Tools ▸ Options de OWASP ZAP.

Dentro de Options, ve a **Network ▸ Local Servers/Proxies** y cambia el puerto a **8090**:

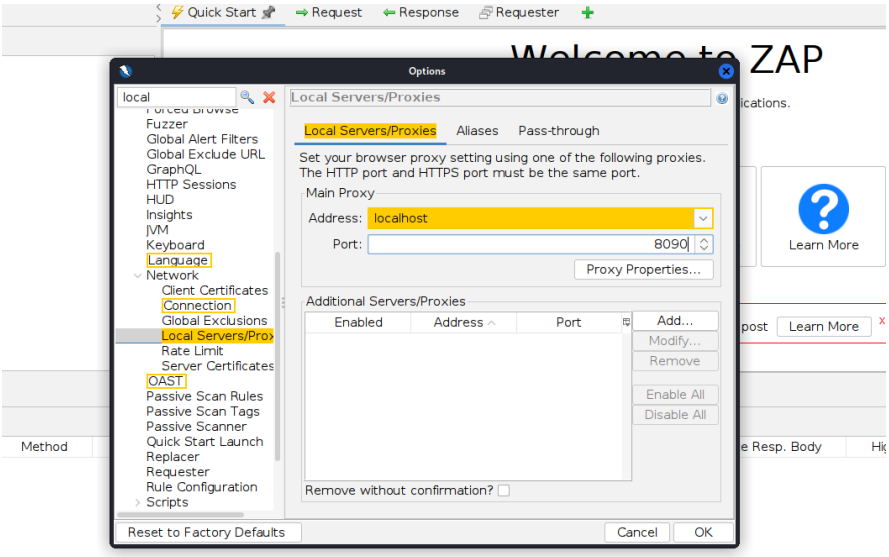


Figura 10. Local Servers/Proxies: Address localhost, Port 8090.

Importante

El puerto del proxy en ZAP y en Firefox debe ser EXACTAMENTE el mismo (8090). Si no coinciden, el tráfico no se intercepta y el navegador no cargará las páginas.

6. Análisis del escaneo a DVWA (http://127.0.0.1:8080)

Paso 9. Lanzar el Automated Scan

Desde la pantalla de bienvenida de ZAP, pulsa "Automated Scan":

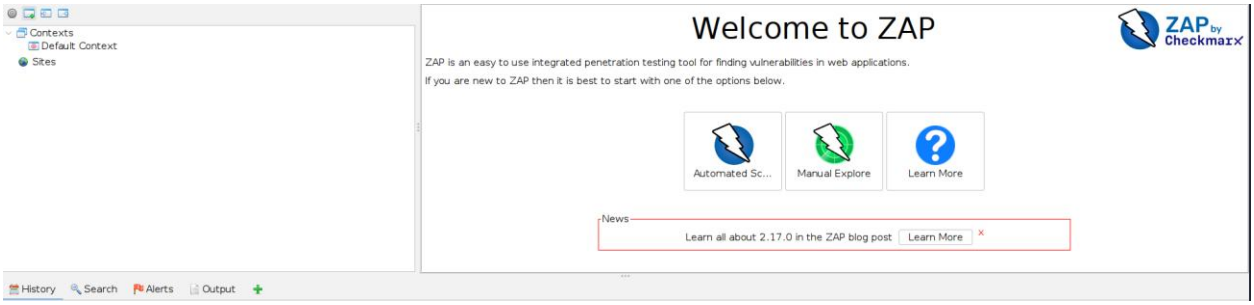


Figura 11. Pantalla de bienvenida de ZAP con la opción Automated Scan.

Introduce la URL objetivo `http://127.0.0.1:8080` y pulsa **Attack**:

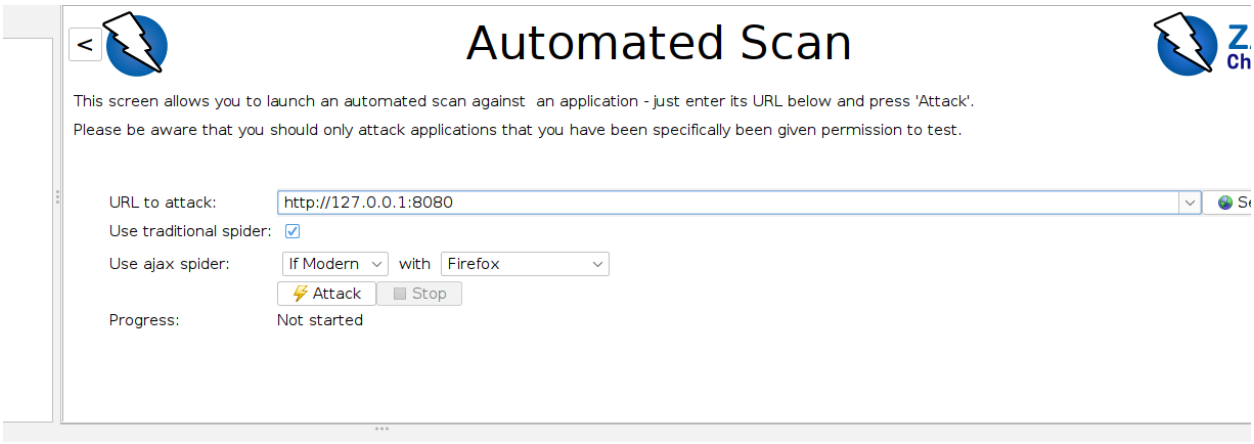


Figura 12. Automated Scan apuntando a DVWA en Docker.

HISTORY — Historial de tráfico

El módulo History (y el registro de "Sent Messages") muestra TODO lo que ZAP capturó mientras navegabas y escaneaba. Cada fila es una petición HTTP con su código de respuesta.

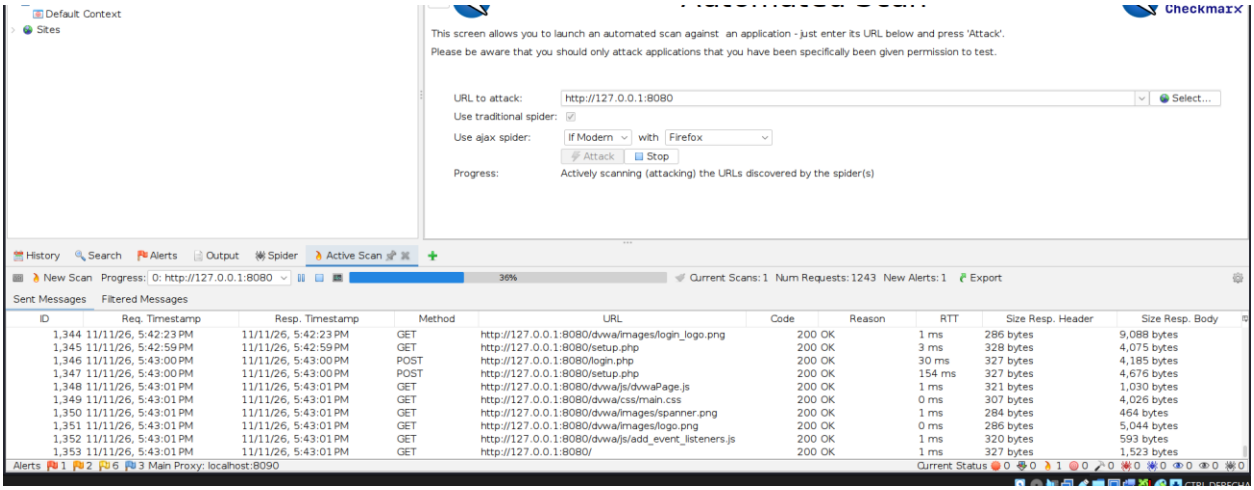


Figura 13. Tráfico capturado por el proxy: peticiones GET/POST a DVWA con código 200 OK.

Códigos de respuesta y su significado:

Código	Significado	Ejemplo en el laboratorio
200	Todo bien	La página cargó correctamente
301 / 302	Redirección	login.php → setup.php
404	No existe	/var
500	Error del servidor	/dvwa/includes/DBMS/ (backend)

ALERTS — Vulnerabilidades detectadas

Aquí ZAP nos dice "esto es inseguro". Clasifica los hallazgos por severidad (bandera roja = alto, naranja = medio, amarilla = bajo, azul = informativo).

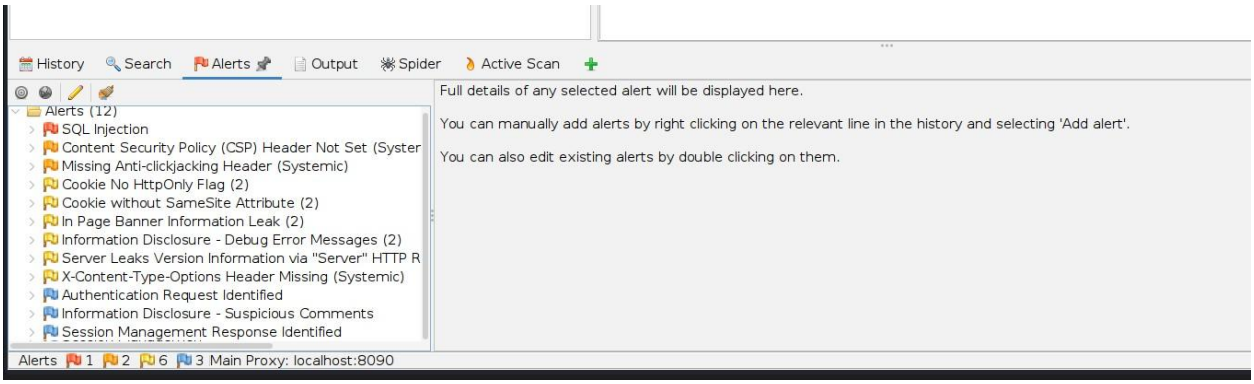


Figura 14. Panel de alertas: 12 tipos de hallazgos sobre DVWA (1 alto, 2 medios, 6 bajos, 3 informativos).

Principales vulnerabilidades detectadas:

- **SQL Injection** — riesgo ALTO: permite manipular la base de datos.
- Content Security Policy (CSP) Header Not Set — facilita ataques XSS.
- Missing Anti-clickjacking Header — la página puede incrustarse en un iframe malicioso.
- Cookie No HttpOnly Flag — la cookie puede ser robada mediante XSS.
- Cookie without SameSite Attribute.

- Server Leaks Version Information — la versión del servidor queda expuesta.
- Information Disclosure (Debug Error Messages / Suspicious Comments).

SPIDER — Reconocimiento (crawler)

El Spider es el crawler de ZAP: recorre la aplicación siguiendo enlaces para descubrir todas las rutas disponibles. Simula la fase de reconocimiento de un atacante.

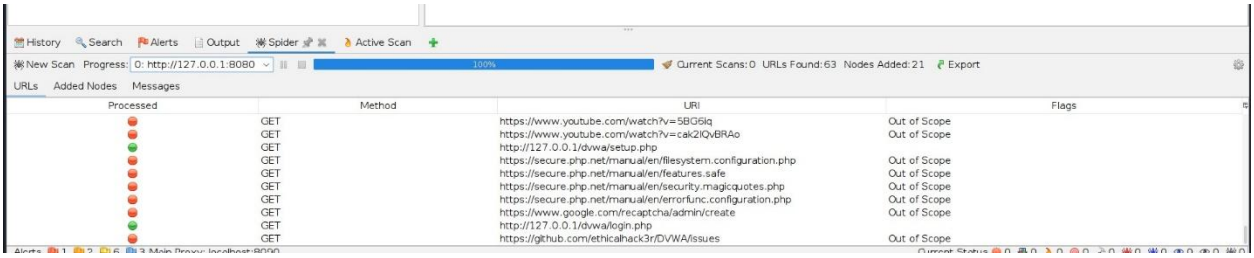


Figura 15. Resultados del Spider: 63 URLs encontradas y 21 nodos añadidos sobre DVWA.

Rutas encontradas (ejemplos): `/dvwa/setup.php` · `/dvwa/login.php` · dominios externos marcados `"Out of Scope"`

¿Para qué sirve? Descubrir rutas ocultas, mapear la aplicación y encontrar puntos de entrada. Las URLs externas (YouTube, php.net) aparecen como "Out of Scope" porque quedan fuera del objetivo.

ACTIVE SCAN — Ataques reales (en entorno controlado)

Aquí ZAP intenta EXPLOTAR las vulnerabilidades, no solo detectarlas. Envía miles de peticiones probando distintos payloads sobre los parámetros de la aplicación.

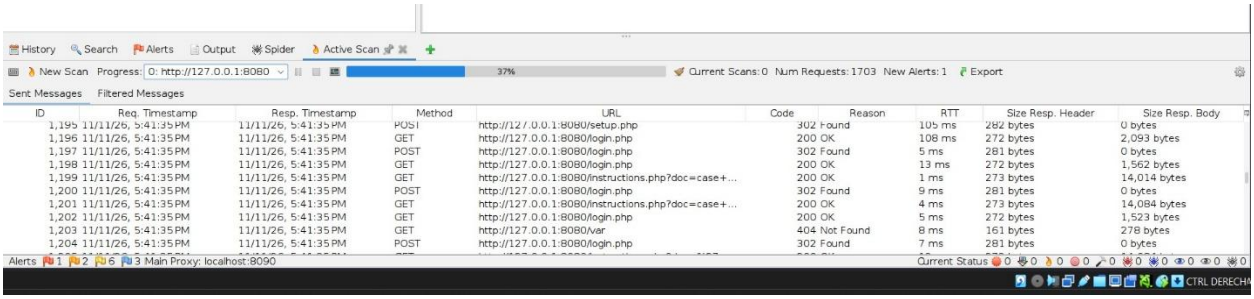


Figura 16. Active Scan en progreso: 1703 peticiones enviadas contra DVWA.

ZAP prueba cosas como:

```
?id=1
?id=1'
?id=1 OR 1=1
?id=<script>alert(1)</script>
```

Esto es un ataque activo real

El Active Scan genera tráfico ofensivo real. Solo debe ejecutarse sobre sistemas propios o con autorización escrita. En este laboratorio es seguro porque DVWA es un entorno diseñado para ser atacado.

HTTP SESSIONS — Manejo de sesiones

El módulo HTTP Sessions gestiona las cookies de sesión. En la cabecera de las peticiones a DVWA se ve la cookie `PHPSESSID`, que identifica la sesión del usuario.

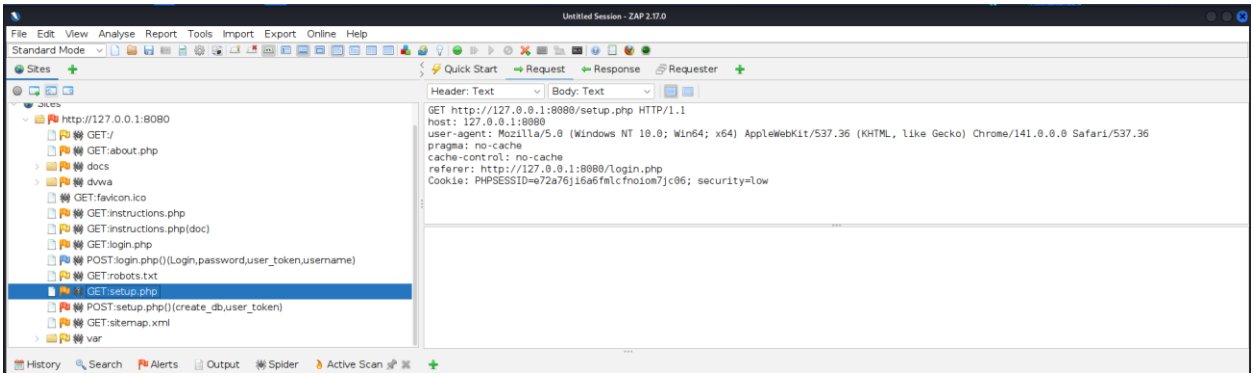


Figura 17. Petición GET a DVWA mostrando la cookie de sesión PHPSESSID en la cabecera.

Sirve para: ver la autenticación, detectar session hijacking (robo de sesión) y analizar el proceso de login.

7. AJAX Spider

¿Qué es? Un crawler "inteligente" que usa un navegador real (headless), ejecuta JavaScript y navega como un usuario.

¿Por qué existe? Porque las aplicaciones modernas (SPA hechas con Angular, React, etc.) generan rutas por JavaScript que el spider normal NO ve.

Spider normal	AJAX Spider
Solo analiza HTML	Ejecuta JavaScript
Rápido	Más lento
Básico	Realista (navega como usuario)

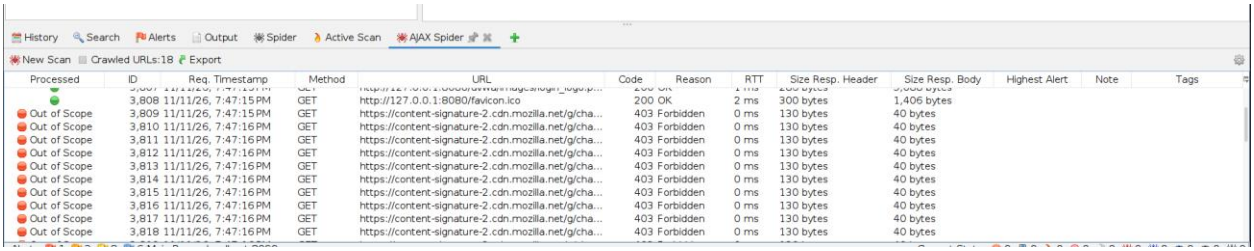


Figura 18. AJAX Spider: 18 URLs rastreadas; los dominios externos aparecen como "Out of Scope".

8. WebSockets

Un WebSocket es un canal de comunicación en **tiempo real** entre cliente y servidor, sin recargar la página. Se usa en chats, notificaciones, juegos y dashboards. ZAP intercepta los mensajes (Opcode, bytes y payload).

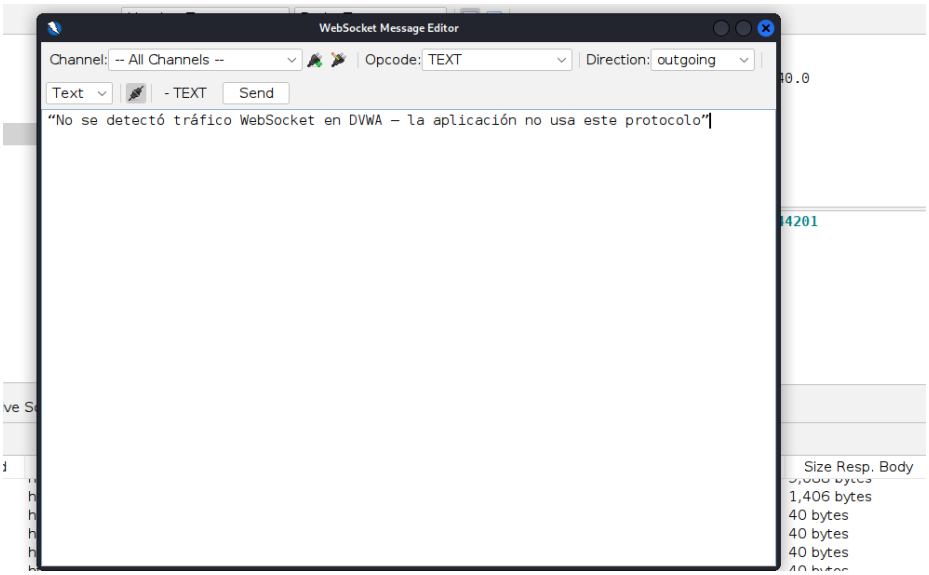


Figura 19. WebSockets: no se detectó tráfico en DVWA — la aplicación no usa este protocolo.

> **Resultado esperado en DVWA**
>
> DVWA no usa WebSockets, por lo que esta pestaña queda vacía. Eso NO es un error: es un hallazgo válido. Se documenta indicando que la aplicación no abre canales en tiempo real.

¿Qué puede hacer un pentester cuando SÍ hay WebSockets?

- Ver datos sensibles que viajan en tiempo real.
- Detectar fugas de información.
- Analizar el mecanismo de autenticación.
- Modificar mensajes (ataques avanzados).

9. Generar el reporte de ZAP

Para documentar formalmente los hallazgos, ZAP genera un reporte. Usa el botón **Generate Report…** de la barra de herramientas, o el menú **Report ▸ Generate Report**.

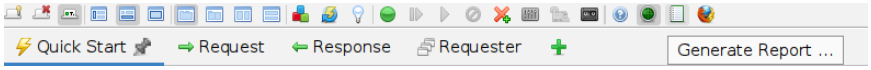


Figura 20. Botón "Generate Report…" en la barra de herramientas de ZAP.

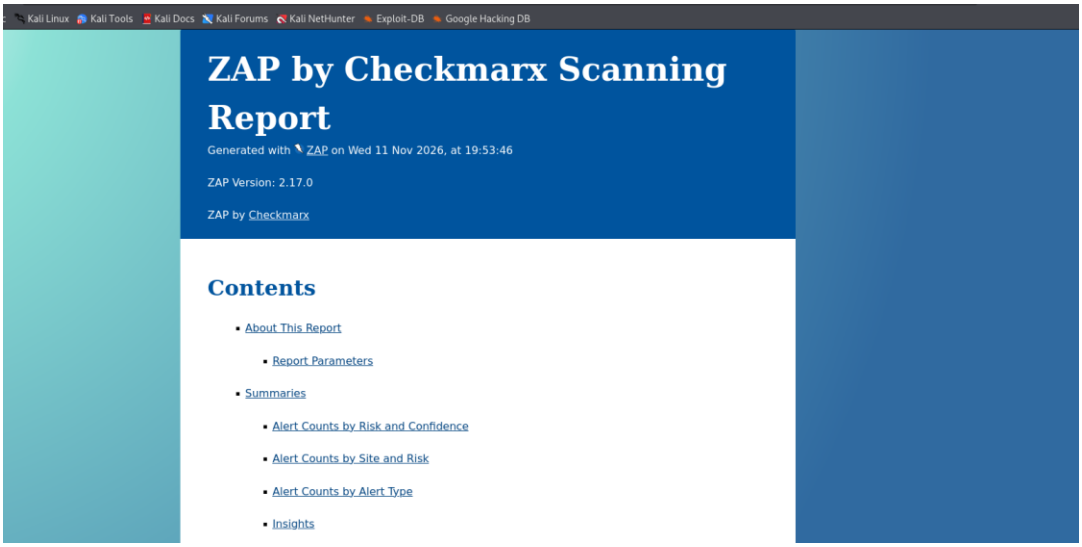


Figura 21. Reporte generado: "ZAP by Checkmarx Scanning Report" (ZAP 2.17.0).

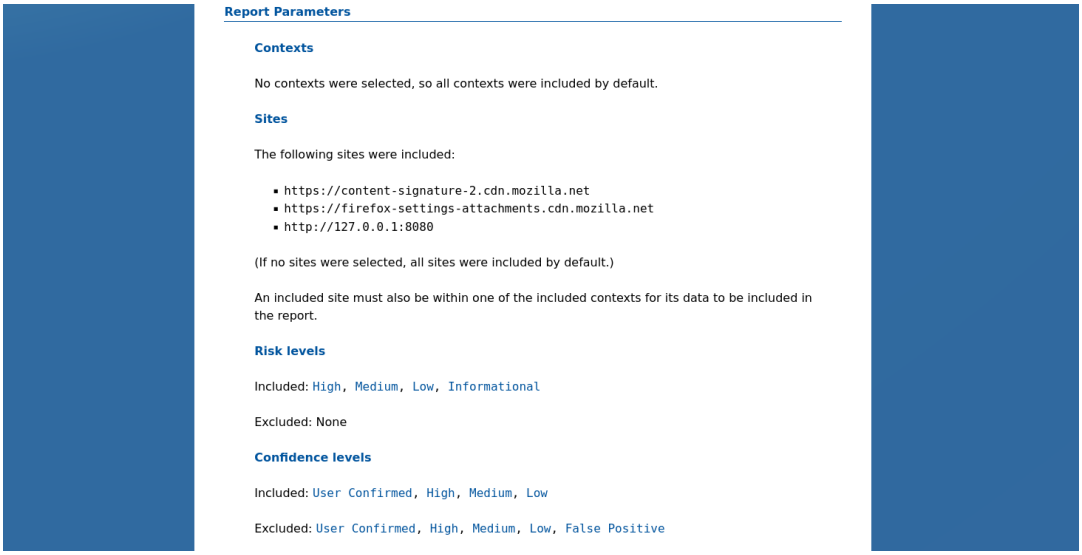


Figura 22. Parámetros del reporte: sitios incluidos y niveles de riesgo (High, Medium, Low, Informational).

10. Pruebas sobre otros entornos

Paso 10. Desactivar el proxy / apuntar a otro entorno

Para navegar normalmente (sin interceptar) o para apuntar a otro entorno, se cambia la configuración del proxy en Firefox a "No proxy":

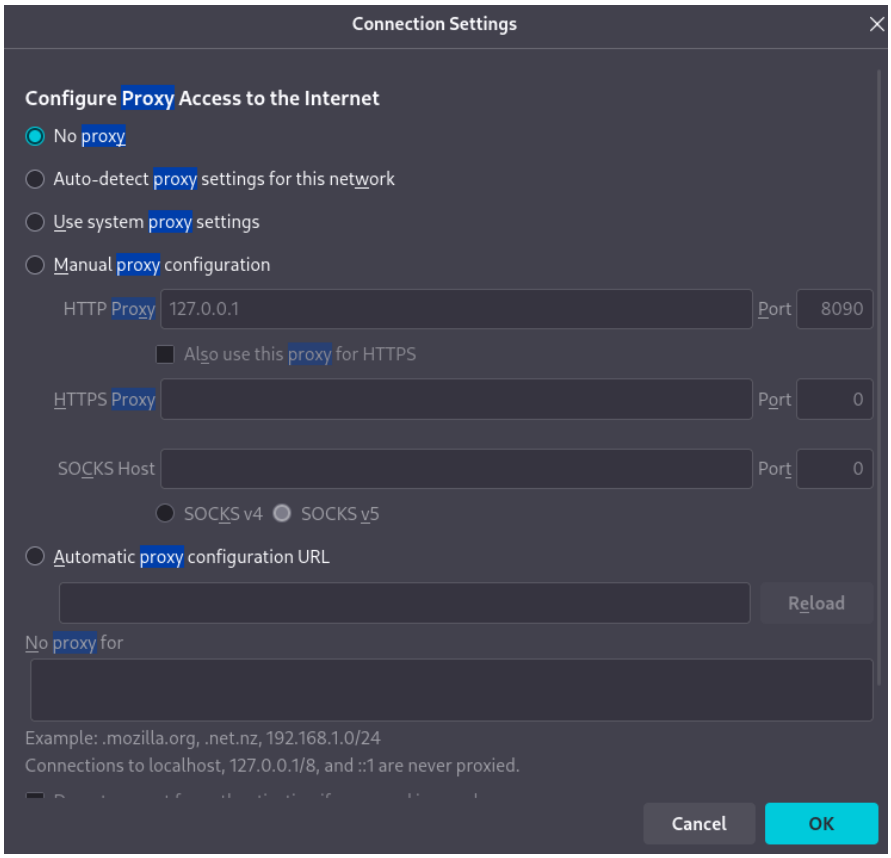


Figura 23. Configuración de Firefox en modo "No proxy".

Sitio de prueba controlado (q10 / UVIRTUAL)

El laboratorio utiliza un entorno de pruebas tipo sandbox (`site6.q10.com`) provisto para practicar el escaneo automático:

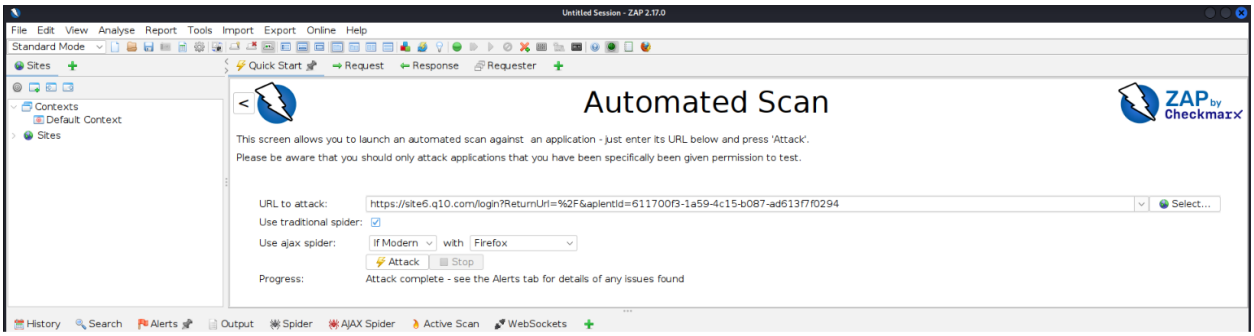


Figura 24. Automated Scan sobre el entorno de prueba q10 — "Attack complete".

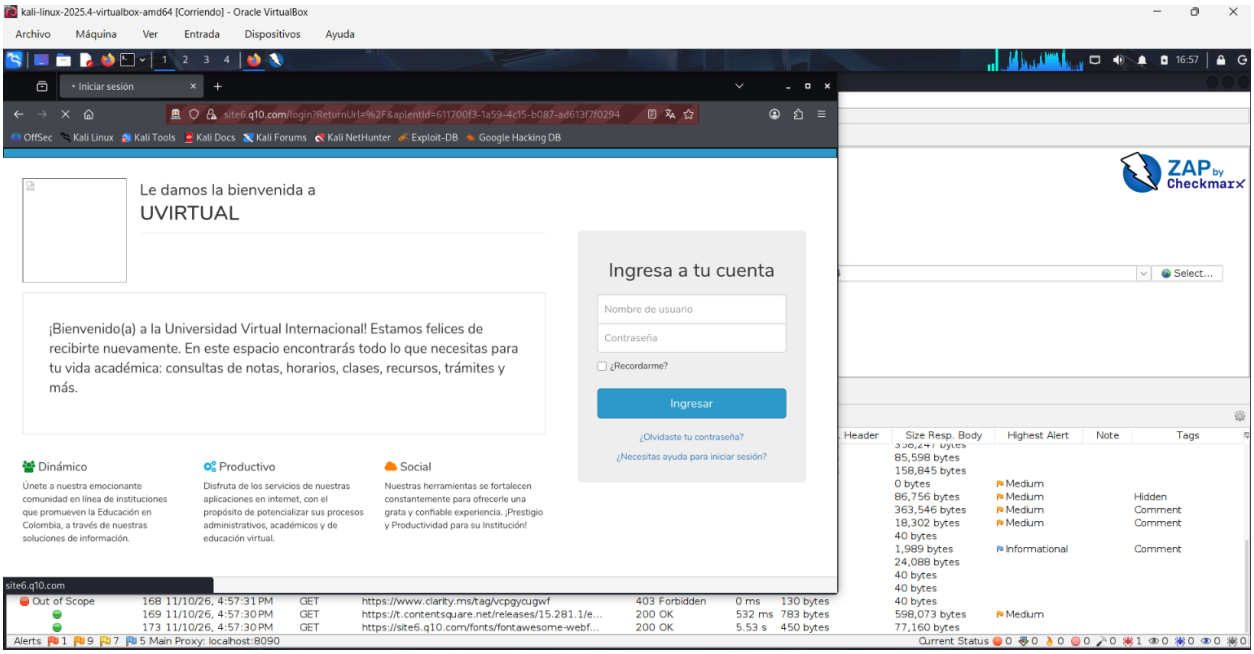


Figura 25. Portal UVIRTUAL (q10) con el tráfico capturado por el proxy de ZAP.

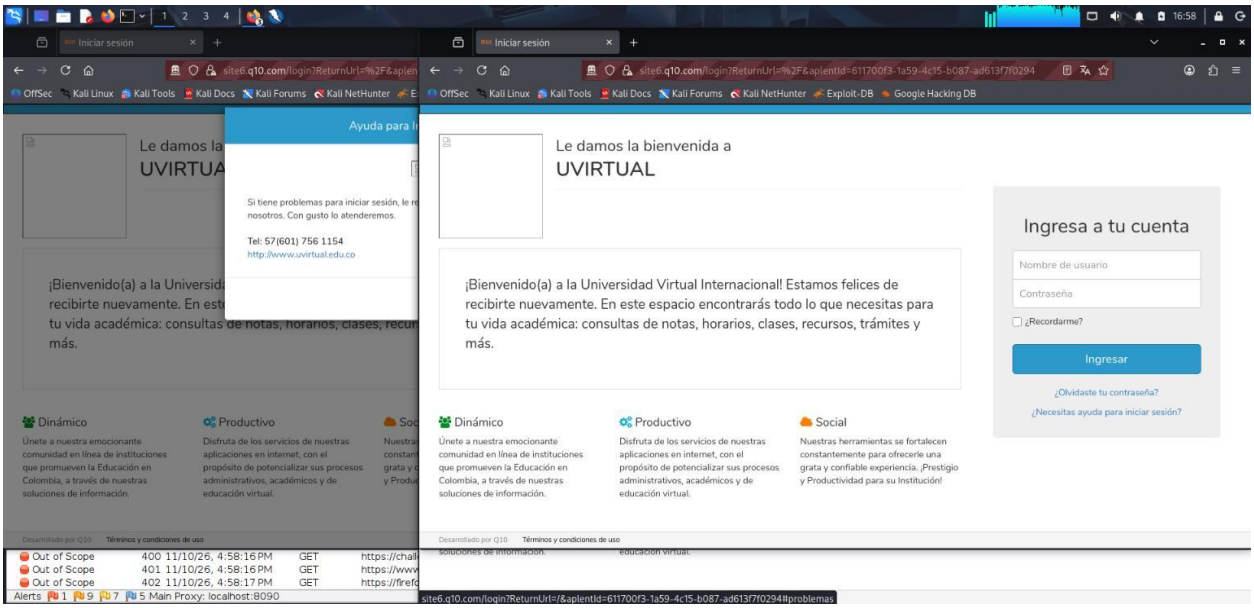


Figura 26. Interceptación de las peticiones del portal de prueba a través del proxy.

11. Escaneo del Campus Virtual de Tunja

Sitio: `https://plataformalms.ustatunja.edu.co/login/index.php`

Nota de autorización

El campus es un sistema en producción de la Universidad Santo Tomás. Un escaneo contra un sistema de terceros requiere autorización escrita del propietario; sin ella puede incurrir en la Ley 1273 de 2009 (delitos informáticos). Estas capturas se incluyen únicamente como evidencia académica del laboratorio.

Las siguientes capturas muestran el escaneo y el tráfico capturado.

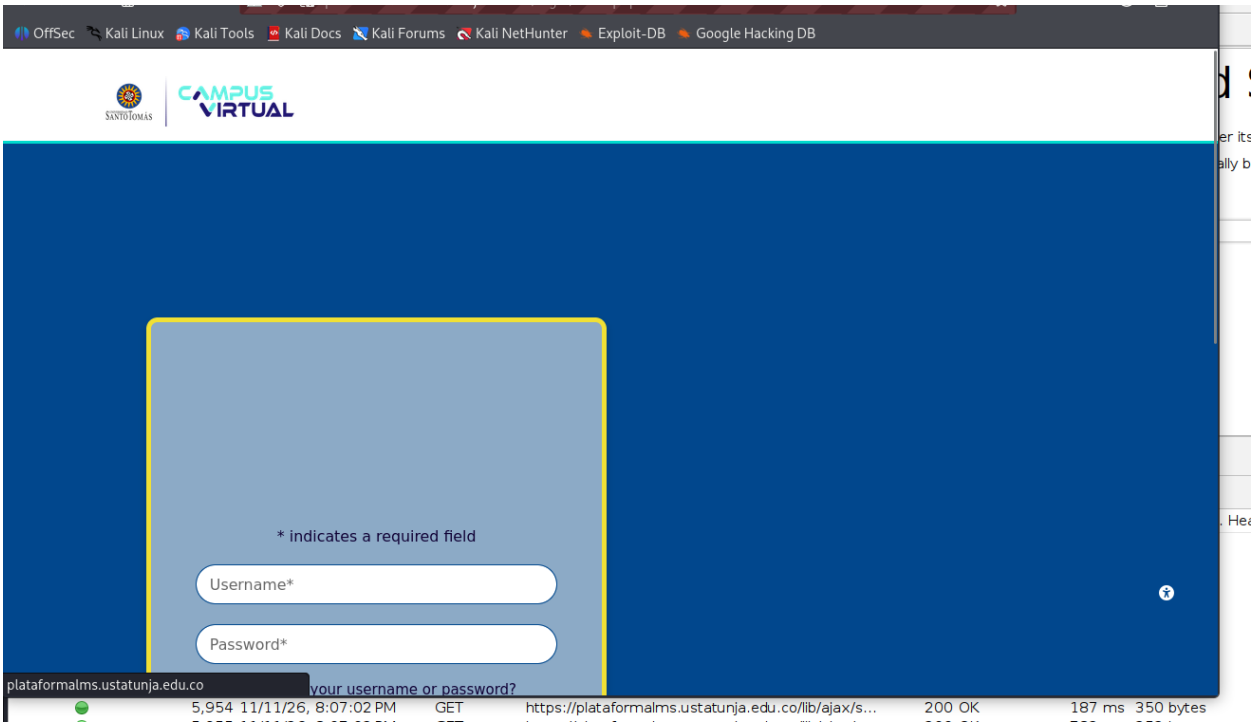


Figura 27. Página de login del campus cargada a través del proxy de ZAP.

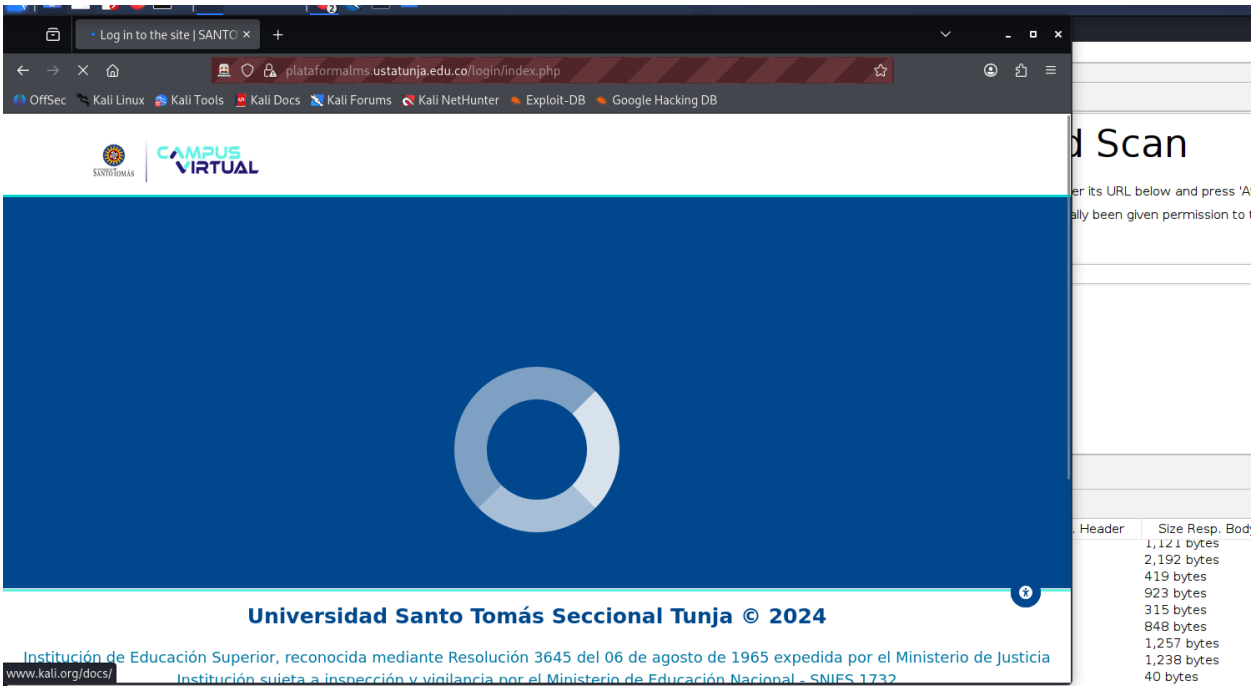


Figura 28. Pantalla de bienvenida del campus durante el escaneo.

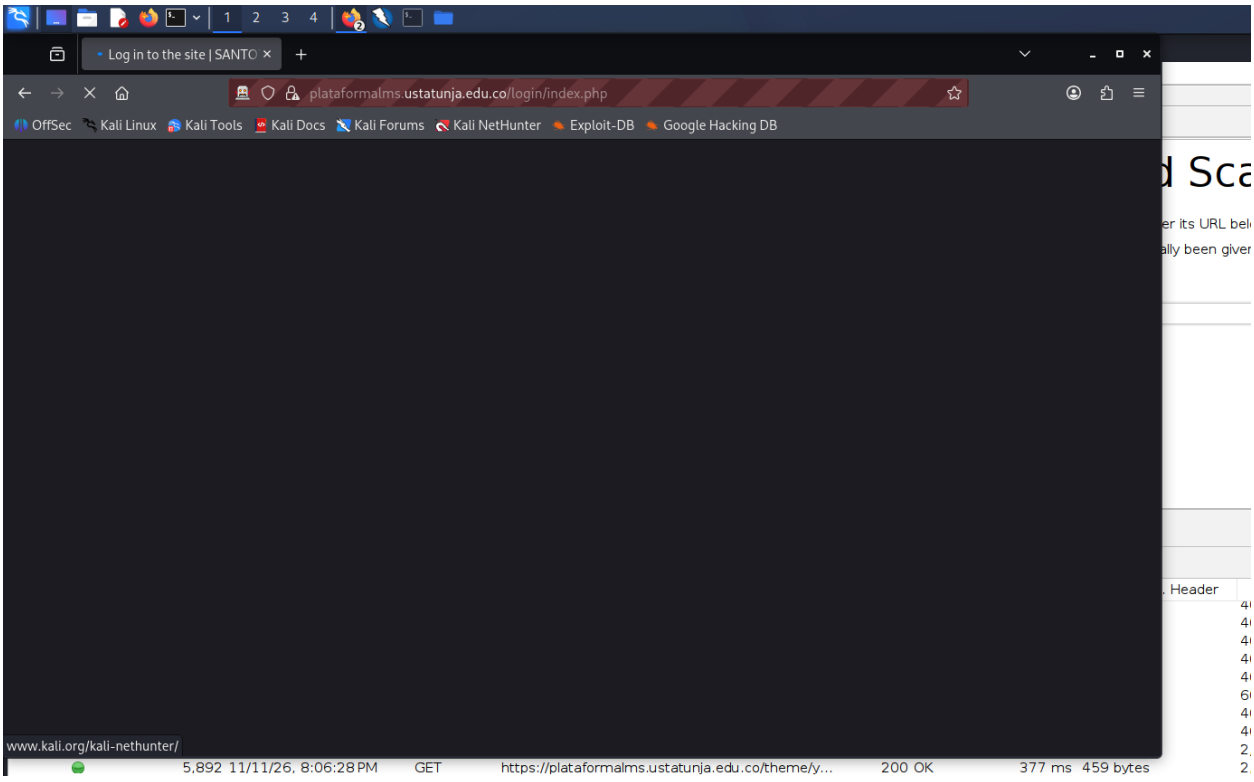


Figura 29. Automated Scan apuntando al campus: tráfico (GET) capturado en el History.

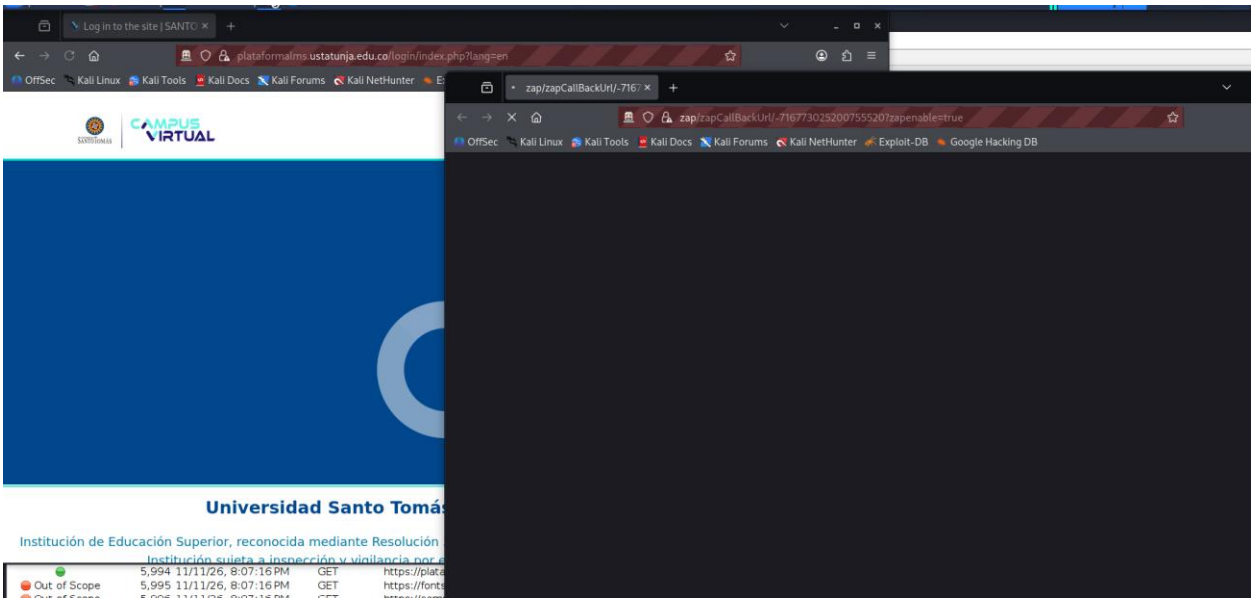


Figura 30. AJAX Spider en ejecución: ZAP abre el navegador de apoyo (zapCallBackUrl).

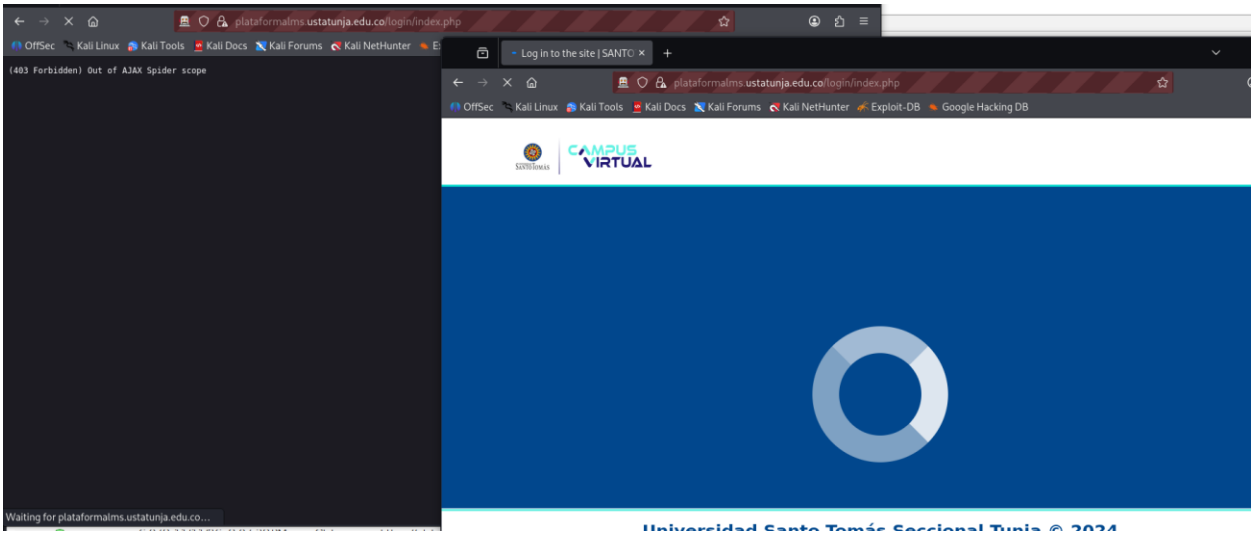


Figura 31. El AJAX Spider marca los dominios externos como "Out of Scope" / 403 Forbidden.

12. Checklist del entregable

Verifica que tu documento final incluya la evidencia de cada módulo:

Módulo / Paso	Evidencia	Figura	✓
Instalación	zaproxy instalado y --version	1–2	✓
DVWA en Docker	Contenedor + login en el navegador	4–5	✓
Proxy Firefox	Connection Settings 127.0.0.1:8090	7	✓
Proxy ZAP	Local Servers/Proxies puerto 8090	10	✓
History	Tráfico con códigos de respuesta	13	✓
Alerts	Panel de vulnerabilidades (incl. SQL Injection)	14	✓
Spider	URLs encontradas (reconocimiento)	15	✓
Active Scan	Peticiones enviadas (1703)	16	✓
HTTP Sessions	Cookie de sesión PHPSESSID	17	✓
AJAX Spider	URLs rastreadas con JS	18	✓
WebSockets	No detectado (documentado)	19	✓
Reporte ZAP	Reporte generado y adjunto	20–22	✓
Campus de Tunja	Escaneo y tráfico capturado	27–31	✓